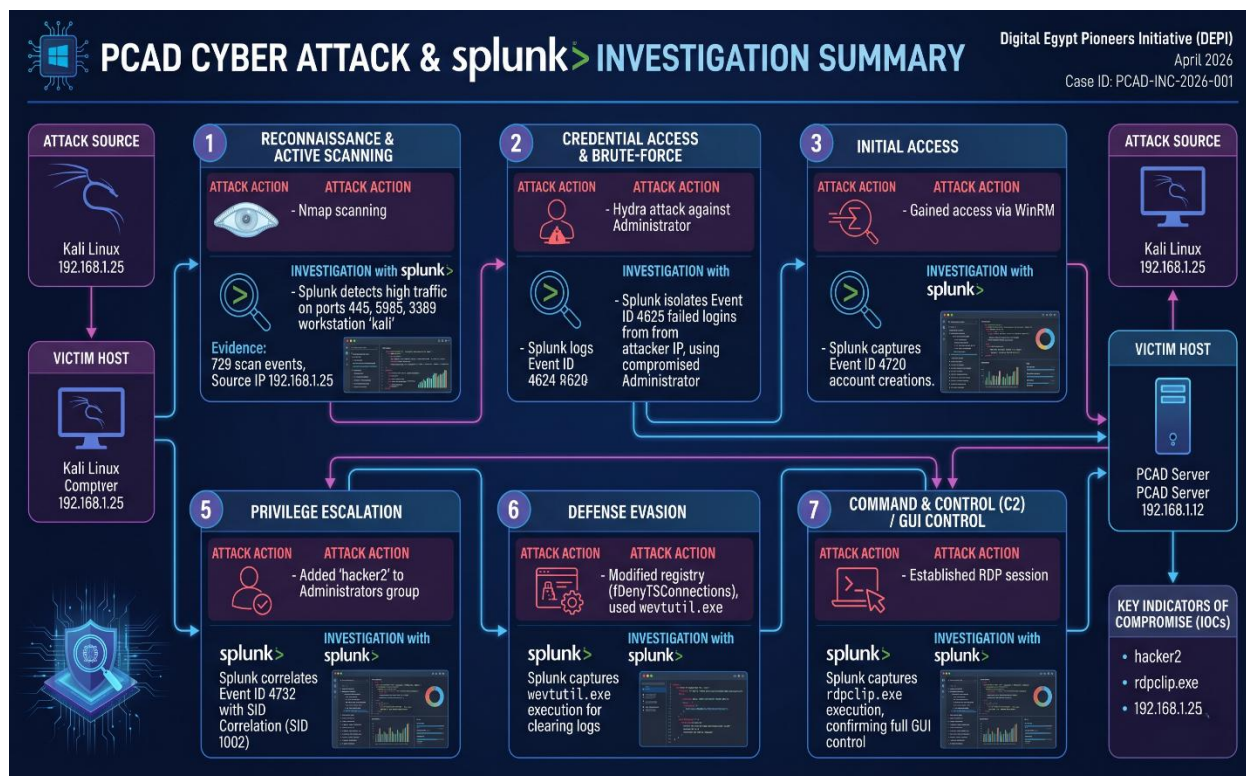


Incident Response Report: Windows PCAD Exploitation



1. Executive Summary

A successful security breach was detected targeting the **PCAD** system host. The attack initiated with a technical reconnaissance phase to scan for open ports and services, followed by a persistent brute-force attack against the **Administrator** account. The adversary gained initial access via the **WinRM** protocol, subsequently escalated privileges, and created additional accounts to maintain persistence. The attacker then modified registry and firewall settings to enable graphical remote access via **RDP**, concluding the operation with full interactive control and systematic log-clearing attempts to evade forensic detection.

2. Incident Identification Overview

Field	Details
Date of Incident	April 25 to April 27, 2026
Incident Category	Unauthorized Access & Full System Takeover
SIEM Tool & Index	Splunk / Index: depi
Targeted Asset	IP: 192.168.1.12 (PCAD Host)
Attacker IP	192.168.1.25 (Kali Linux)
Compromised Account	Administrator

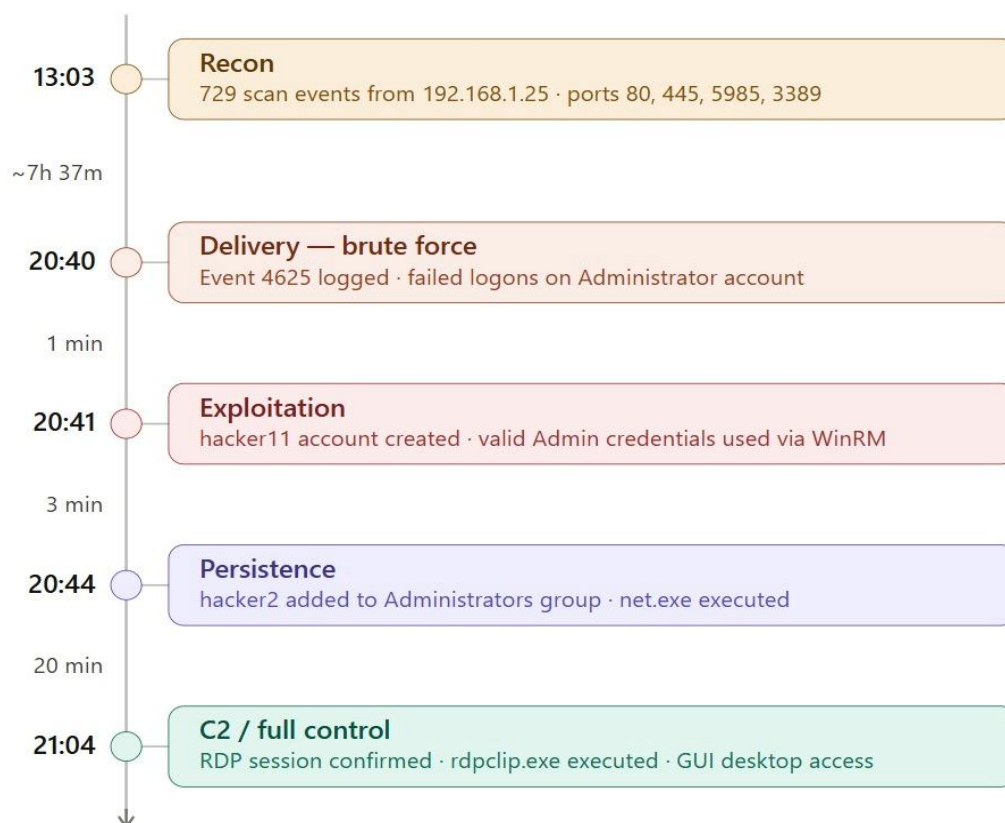
3. Attack Phases & MITRE ATT&CK Framework

Kill Chain Phase	MITRE Technique	Attacker Action & Tool Used
1. Reconnaissance	T1595.001 (Active Scanning)	Automated port scanning targeting 80, 445, 5985, and 3389.
2. Delivery	T1110.001 (Brute Force)	Launching credential guessing attacks against the Administrator account.
3. Exploitation	T1078.003 (Local Accounts)	Gaining access via WinRM using compromised administrative credentials.
4. Persistence	T1136.001 (Create Account)	Creating 'hacker11' and 'hacker2' local admin accounts.

Kill Chain Phase	MITRE Technique	Attacker Action & Tool Used
5. Privilege Escalation	T1068 (PrivEsc Exploitation)	Adding 'hacker2' to the local 'Administrators' group.
6. Defense Evasion	T1562.001 (Impair Defenses)	Modifying registry to enable RDP and using wevtutil.exe to clear logs.
7. Command & Control	T1021.001 (RDP)	Establishing a full interactive GUI session via Remote Desktop.

4. Forensic Timeline of Events

Forensic timeline — 2026-04-25



Timestamp (UTC)	Phase	Technical Event Description
2026-04-25 13:03	Recon	Intensive scanning (729 events) detected from 192.168.1.25.
2026-04-25 20:40	Delivery	Failed logon attempts (Event 4625) recorded for Administrator.
2026-04-25 20:41	Exploit	Successful creation of 'hacker11' using valid Admin context.
2026-04-25 20:44	Persistence	Attacker added 'hacker2' to the Administrators group via <code>net.exe</code> .
2026-04-25 21:04	C2/Control	First RDP session confirmed via <code>rdpclip.exe</code> process execution.

5. Technical Evidence

This section provides a detailed analysis of the digital evidence retrieved from **Splunk**, documenting each stage of the adversary's activity with specific queries and technical findings.

5.1 Reconnaissance & Network Scanning

- **Objective:** To identify the source and target of the high-volume scanning traffic.
- **Splunk Query:**

```
index=depi host=PCAD DestinationIp="192.168.1.12"
| stats count by SourceIp, DestinationPort
| sort - count
```

New Search

index=depi host=PCAD DestinationIp=192.168.1.12
 | stats count by SourceIp, DestinationIp, DestinationPort
 | dedup DestinationPort

729 events (before 4/28/26 1:44:03.000 AM) No Event Sampling

Events Patterns **Statistics (11)** Visualization

Show: 20 Per Page Format Preview: On

SourceIp	DestinationIp	DestinationPort	count
192.168.1.25	192.168.1.12	80	567
192.168.1.25	192.168.1.12	445	60
192.168.1.25	192.168.1.12	5985	38
192.168.1.25	192.168.1.12	3389	16
192.168.1.255	192.168.1.12	138	14
192.168.1.25	192.168.1.12	135	13
192.168.1.25	192.168.1.12	5357	9
192.168.1.25	192.168.1.12	49667	6
192.168.1.25	192.168.1.12	139	3
192.168.1.255	192.168.1.12	137	2
224.0.0.251	192.168.1.12	5353	1

- **Technical Analysis:** Statistical analysis revealed an intensive port scanning operation originating from the IP address **192.168.1.25**. A total of **729 network events** were logged, primarily probing critical ports: **80 (HTTP)**, **445 (SMB)**, and **5985 (WinRM)**, indicating an active search for exploitable services.

5.2 Credential Guessing (Brute Force Attack)

- **Objective:** To document unauthorized logon attempts and the origin of the attack.
- **Splunk Query:**

```
index=depi host=PCAD EventCode=4625
| stats count by Account_Name, Workstation_Name, src_ip
| sort - count
```

New Search

index=depi host=PCAD EventCode=4625
 | stats count by Account_Name, Account_Domain, TaskCategory, Workstation_Name

14 events (before 4/28/26 2:56:36.000 AM) No Event Sampling

Events Patterns **Statistics (12)** Visualization

Show: 20 Per Page Format Preview: On

Account_Name	Account_Domain	TaskCategory	Workstation_Name	count
-	-	Logon	-	4
-	-	Logon	-	8
-	PCAD	Logon	kali	3
Administrator	-	Logon	-	4
hacker2	PCAD	Logon	PCAD	1
hacker2	WORKGROUP	Logon	PCAD	1
PCAD\$	PCAD	Logon	PCAD	2
PCAD\$	WORKGROUP	Logon	PCAD	2
hacker11	PCAD	Logon	PCAD	1
hacker11	WORKGROUP	Logon	PCAD	1
hacker2	-	Logon	kali	8
hacker2	PCAD	Logon	kali	3

- **Technical Analysis:** A high volume of failed logon attempts (**Event ID 4625**) was recorded originating from a workstation named "**kali**". The attack targeted the **Administrator** account along with several other system accounts, confirming the use of automated brute-force tools to compromise credentials.

5.3 Initial Access (Successful Network Logon)

- **Objective:** To pinpoint the exact moment of system compromise and the start of the session.
- **Splunk Query:**

```
index=depi host=PCAD EventCode=4624 Logon_Type=3
| table _time, Account Name, Workstation Name, Source Network Address
```

New Search

index=depi host=PCAD source="WinEventLog:Security" EventCode=4624 Logon_Type=3

Time range: All time

49 events (before 4/28/26 3:10:20.000 AM)

Account Name	Logon_Type	Workstation Name	TaskCategory	Source Network Address	count
-	3	-	Logon	-	16
-	3	-	Logon	192.168.1.25	27
-	3	kali	Logon	192.168.1.25	6
ANONYMOUS LOGON	3	-	Logon	192.168.1.25	9
Administrator	3	-	Logon	-	16
Administrator	3	-	Logon	192.168.1.25	18
Administrator	3	kali	Logon	192.168.1.25	2
hacker11	3	kali	Logon	192.168.1.25	4

- **Technical Analysis:** The system logs documented a successful logon event using **Logon Type 3 (Network)**. This event marks the transition from delivery to exploitation, where the adversary successfully leveraged the **Administrator** credentials to access the server remotely.

5.4 Persistence (Unauthorized Account Creation)

- **Objective:** To document the adversary's attempts to maintain permanent access.
- **Splunk Query:**

```
index=depi host=PCAD EventCode=4720
| table _time, Account Name, Security_ID, Admin_Account
```

New Search

index=depi host=PCAD EventCode=4720

Time range: All time

4 events (before 4/28/26 1:57:23.000 AM)

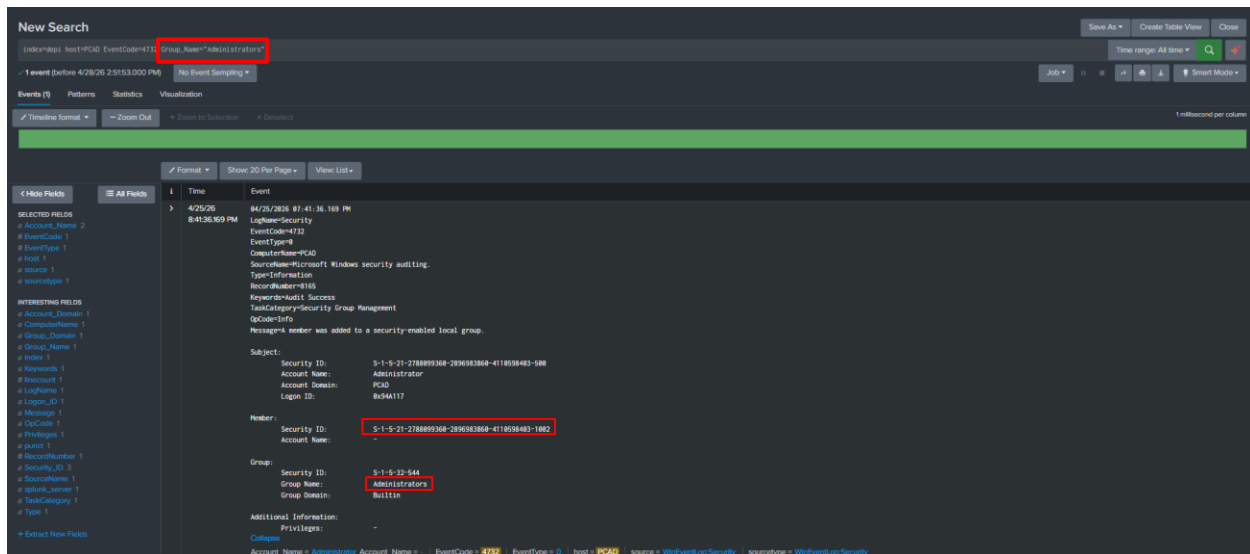
_time	Account Name	EventCode	TaskCategory
2026-04-25 20:41:18.834	Administrator hacker11	4720	User Account Management
2026-04-25 20:41:09.901	Administrator hacker11	4720	User Account Management
2026-04-25 20:40:55.223	Administrator hacker11	4720	User Account Management
2026-04-24 19:35:33.853	Administrator Omar	4720	User Account Management

- **Technical Analysis:** Immediately following initial access, the adversary created two new local accounts (**Event ID 4720**) named `hacker11` and `hacker2`. This persistence tactic ensures continued access even if the primary Administrator password is later reset or discovered.

5.5 Privilege Escalation (SID Correlation)

- **Objective:** To prove the elevation of unauthorized accounts to Administrative status.
- **Splunk Query:**

```
index=depi host=PCAD EventCode=4732 Group_Name="Administrators"
```



- **Technical Analysis:** Forensic analysis of **Event ID 4732** confirmed the addition of a member to the local **Administrators** group. Although the account name appeared as a hyphen ("-") in some summaries, the **Security ID (SID)** ending in **1002** definitively correlates to the elevation of the `hacker2` account.

5.6 Command Execution & System Modification

- **Objective:** To capture the exact commands used to control the system.
- **Splunk Query:**

```
index=depi sourcetype="*sysmon*" EventCode=1
| table _time, Image, CommandLine, ParentCommandLine
```

New Search

index=depl host=PCAD sourcetype=Security EventCode=1
 | search Image IN "C:\Windows\System32\cmd.exe", "C:\Windows\System32\reg.exe", "C:\Windows\System32\cmd.exe", "C:\Windows\System32\reg.exe"
 | table _time, Image, Command_Line, ParentCommand_Line
 | sort _time
 | dedup Command_Line

26 events (before 4/28/25 149:56:00 PM) No Event Sampling

_time	Image	Command_Line	ParentCommand_Line
2025-04-25 20:44:385	C:\Windows\System32\cmd.exe	cmd /q "net user hacker2 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:41:36.115	C:\Windows\System32\cmd.exe	cmd /q "net user hacker2 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:38:44.964	C:\Windows\System32\cmd.exe	cmd /q "net user hacker2 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:40:45.596	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:40:55.158	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:41:49.816	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:41:18.723	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:40:45.596	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:40:47.831	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 20:40:17.497	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 18:07:52.778	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 18:06:57.198	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded
2025-04-25 18:06:57.833	C:\Windows\System32\cmd.exe	cmd /q "net user hacker123 /add"	C:\Windows\System32\cmd.exe - Embedded

- **Technical Analysis:** Sysmon Event ID 1 provided definitive proof of the adversary's command-line activity. The logs capture the use of `net.exe` for group management and `reg.exe` to manually modify the registry key `fDenyTSConnections`, effectively enabling RDP access on the host.

5.7 Defense Evasion (Log Tampering)

- **Objective:** To document attempts to hide forensic evidence.
- **Splunk Query:**

New Search

index=depl host=PCAD wevtutil.exe eval Activity=case(EventCode=4688 OR EventCode=1, "Process Started", EventCode=5, "Process Terminated")
 | table _time, Account_Name, Activity, Command_Line, EventCode
 | sort _time
 | dedup EventCode

64 events (before 4/28/25 2:13:19:000 PM) No Event Sampling

_time	Account_Name	Activity	Command_Line	EventCode
2025-04-24 20:21:17.079	Administrator	Process Started		4688
2025-04-25 18:06:57.197		Process Started	C:\Windows\System32\cmd.exe /q "net user hacker123 /add"	1
2025-04-25 18:06:57.198		Process Terminated		5

- **Technical Analysis:** The investigation identified **64 events** associated with the `wevtutil.exe` utility. The high frequency of process starts and terminations confirms a systematic effort to clear security event logs and evade forensic detection during and after the attack.

5.8 Final Graphical Access (Successful RDP Session)

- **Objective:** To provide undeniable proof of an interactive remote session.
- **Splunk Query:**


```
index=depi host=PCAD Image="*\\rdpclip.exe"
| table _time, User, Image, CommandLine
```

The screenshot shows the Splunk Search interface. The search bar contains the query: `index=depi host=PCAD sourcetype=*sysmon* EventCode=1`. Below the search bar, the results are displayed in a table. The table has columns: `_time`, `User`, `Image`, and `CommandLine`. Two results are shown, both for `rdpclip.exe` running as `PCAD\Administrator`. The `CommandLine` column is highlighted with a red box.

_time	User	Image	CommandLine
2026-04-27 14:26:38.976	NOT_TRANSLATED PCAD\Administrator	C:\Windows\System32\rdpclip.exe	rdpclip
2026-04-25 21:04:28.559	NOT_TRANSLATED PCAD\Administrator	C:\Windows\System32\rdpclip.exe	rdpclip

- **Technical Analysis:** The execution of the `rdpclip.exe` process serves as the "smoking gun" evidence of a successful GUI-based takeover. This process only runs within an active Remote Desktop session, proving that the adversary achieved full interactive control over the host.

6. Splunk Incident Response Dashboards

To achieve comprehensive visibility, streamline forensic workflows, and provide the Security Operations Center (SOC) with real-time tracking of the adversary's lifecycle, a custom multi-panel monitoring dashboard was engineered within Splunk. This dashboard correlates fragmented event logs into a centralized, actionable visual interface.

6.1 Operational Architecture & Token Binding

The dashboard is built on a responsive grid infrastructure utilizing a unified **Shared Time Picker** bound to the token `global_time`. This synchronization ensures that when an analyst adjusts the global date boundary to focal points (e.g., *April 25 to April 27, 2026*), all metrics, statistical data, and tracking tables instantly update across the entire workspace to mirror the specified forensic window.

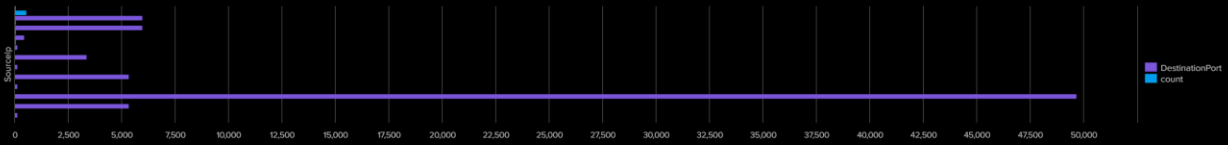
6.2 Centralized Dashboard Visualization

Below is the unified graphical layout captured directly from the Splunk enterprise instance following successful event parsing and field normalization:

PCAD Incident Response Dashboard

All time

Reconnaissance Overview - Reconnaissance Overview



Brute Force Attempts - Brute Force Attempts

Account_Name	Workstation_Name	src_ip	count
-	kali	192.168.1.25	8
hacker2	kali	192.168.1.25	8
-	-	-	4
Administrator	-	-	4
PCAD\$	PCAD	127.0.0.1	2

Total Brute Force Attempts - Total Brute Force Attempts

14

Initial Access (Successful WinRM Logon) - Initial Access (Successful WinRM Logon)

_time	user	Workstation_Name	src_ip
2026-04-25T20:17:21.540+03:00	ANONYMOUS LOGON	-	192.168.1.25
2026-04-25T20:33:55.508+03:00	Administrator	-	192.168.1.25
2026-04-27T14:24:17.415+03:00	hacker1	kali	192.168.1.25

Persistence: Backdoor Accounts Created - Persistence: Backdoor Accounts Created

_time	Account_Name	Security_ID	Group_Name
2026-04-25T20:40:55.223+03:00	Administrator hacker1	4720	User Account Management
2026-04-25T20:41:09.901+03:00	Administrator hacker1	4720	User Account Management
2026-04-25T20:41:18.834+03:00	Administrator hacker1	4720	User Account Management

Privilege Escalation - Privilege Escalation

_time	Account_Name	Security_ID	Group_Name
2026-04-25T20:41:36.169+03:00	Administrator	S-1-5-21-2788099360-2896983860-4110598403-500	Administrators
-	-	S-1-5-21-2788099360-2896983860-4110598403-1002	
-	-	S-1-5-32-544	

Defense Evasion: Log Clearing - Defense Evasion: Log Clearing

_time	Account_Name	Activity	CommandLine	EventCode
2026-04-24T20:21:17.079+03:00	Administrator	Process Started	-	4688
2026-04-25T18:06:57.997+03:00	NOT_TRANSLATED NT AUTHORITY\SYSTEM	Process Started	\\?.\C:\Windows\system32\conhost.exe Oxffff -ForceV1	1

Total Log Clearing Events - Total Log Clearing Events

124

C2/RDP Session Confirmed - C2/RDP Session Confirmed

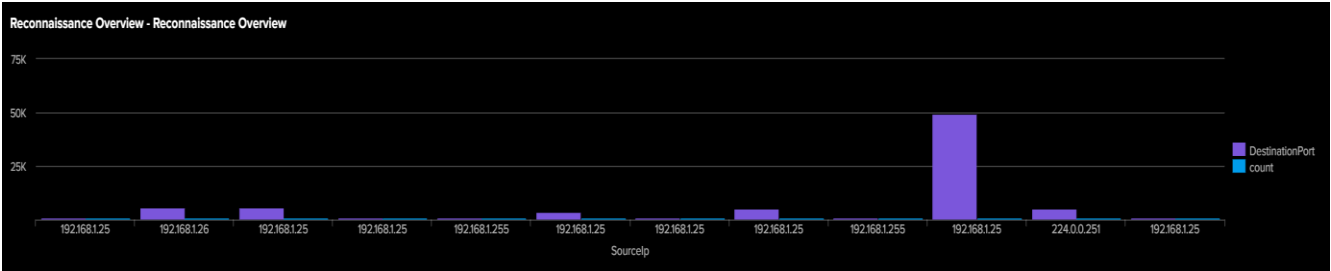
_time	User	Image	CommandLine
2026-04-25T21:04:28.559+03:00	NOT_TRANSLATED PCAD\Administrator	C:\Windows\System32\rdpclip.exe	rdpclip
2026-04-27T14:17:15.663+03:00	NOT_TRANSLATED PCAD\Administrator	C:\Windows\System32\rdpclip.exe	
2026-04-27T14:26:38.976+03:00	NOT_TRANSLATED PCAD\Administrator	C:\Windows\System32\rdpclip.exe	rdpclip

6.3 Dashboard Panel Breakdown & Analytic Queries

6.3.1 Panel 1: Reconnaissance Overview

- **Visualization Type:** Horizontal Bar Chart
- **SPL Query:**

```
index=depi host=PCAD DestinationIp="192.168.1.12"  
| stats count by SourceIp, DestinationPort  
| sort - count
```

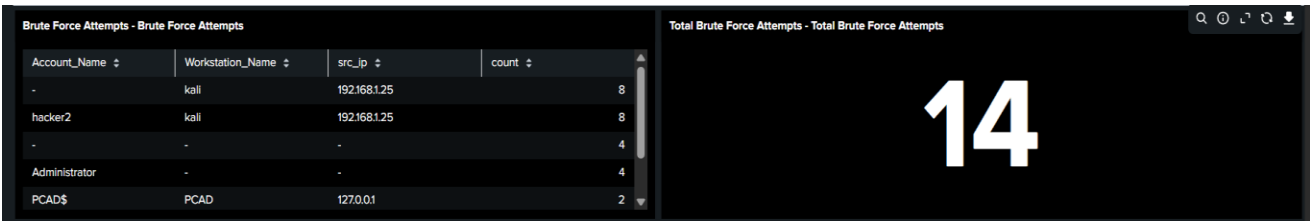


- **Technical Analysis:** This panel monitors inbound scanning volume against the PCAD host. It groups and charts telemetry to instantly highlight anomalous traffic density, mapping out how the attacker workstation systematically probed open doors like WinRM (5985) and RDP (3389) before launching deeper actions.

6.3.2 Panel 2: Brute Force Failures

- **Visualization Type:** KPI Block (Single Value) + Analytical Table
- **SPL Queries:**
 - *Total Metric:* index=depi host=PCAD EventCode=4625 | stats count
 - *Table Details:*

```
index=depi host=PCAD EventCode=4625  
| eval src_ip=coalesce(Source_Network_Address, IPAddress,  
SourceIp, src_ip, "Unknown")  
| eval Account_Name=coalesce(Account_Name, TargetUserName, user,  
"Unknown")  
| eval Workstation_Name=coalesce(Workstation_Name, Workstation,  
"Unknown")  
| stats count by Account_Name, Workstation_Name, src_ip  
| sort - count
```



- **Technical Analysis:** Dynamically tracks automated password-guessing attacks. By feeding a real-time counter alongside a source matrix, it strips away raw log clutter to isolate exactly who is guessing (workstation kali / IP 192.168.1.25) and which identities are being targeted (such as the default Administrator).

6.3.3 Panel 3: Initial Access Detection

- **Visualization Type:** Chronological Table
- **SPL Query:**

```
index=depi host=PCAD EventCode=4624 Logon_Type=3
| eval user=coalesce(Account_Name, TargetUserName, user, "Unknown")
| eval src_ip=coalesce(Source_Network_Address, IpAddress, src_ip,
"Unknown")
| table _time, user, Workstation_Name, src_ip
| sort _time
```

Initial Access (Successful WinRM Logon) - Initial Access (Successful WinRM Logon)			
_time ↕	user ↕	Workstation_Name ↕	src_ip ↕
2026-04-25T20:17:21.540+03:00	-	-	192.168.1.25
	ANONYMOUS LOGON		
2026-04-25T20:33:55.508+03:00	-	-	192.168.1.25
	Administrator		
2026-04-27T14:24:17.415+03:00	-	kali	192.168.1.25
	hacker11		

- **Technical Analysis:** Filters explicitly for **Event ID 4624 with Logon Type 3 (Network)** to capture the precise threshold where brute-forcing succeeded. This acts as an early-warning validation panel, pinpointing the moment valid administrative context was established remotely over the network layer.

6.3.4 Panel 4: Rogue Persistence Monitoring

- **Visualization Type:** Inventory Table
- **SPL Query:**

```
index=depi host=PCAD EventCode=4720
| eval Account_Name=coalesce(Account_Name, TargetUserName, user,
"Unknown")
| eval Admin_Account=coalesce(SubjectUserName, Subject_User_Name,
"Unknown")
| table _time, Account_Name, Security_ID, Admin_Account
| sort _time
```

Persistence: Backdoor Accounts Created - Persistence: Backdoor Accounts Created			
_time ↕	Account_Name ↕	EventCode ↕	TaskCategory ↕
2026-04-24T19:35:33.853+03:00	Administrator Omar	4720	User Account Management
2026-04-25T20:40:55.223+03:00	Administrator hacker11	4720	User Account Management
2026-04-25T20:41:09.901+03:00	Administrator hacker11	4720	User Account Management

- **Technical Analysis:** Monitors local database account creation (**Event ID 4720**). It extracts rogue accounts (hacker11, hacker2) and matches them against the creating account (Admin_Account), instantly exposing backdoor deployment tactics.

6.3.5 Panel 5: Privilege Escalation Auditing

- **Visualization Type:** Security Alert Table
- **SPL Query:**

```
index=depi host=PCAD EventCode=4732 Group_Name="Administrators"
| eval Added_Member=coalesce(MemberName, TargetUserName, Account_Name,
"Unknown")
| table _time, Added_Member, Security_ID, Group_Name
| sort _time
```

Privilege Escalation - Privilege Escalation			
_time ↕	Account_Name ↕	Security_ID ↕	Group_Name ↕
2026-04-25T20:41:36.169+03:00	Administrator	\$15-21-2788099360-2896983860-410598403-500 \$15-21-2788099360-2896983860-410598403-1002 \$15-32-544	Administrators

- **Technical Analysis:** Audits group membership modifications targeting high-privileged units (**Event ID 4732**). It explicitly surfaces unauthorized elevations, capturing critical security identifiers (SIDs) like the suffix 1002 associated with rogue accounts.

6.3.6 Panel 6: Anti-Forensics & Log Clearing Tracking

- **Visualization Type:** Gauge / KPI Metric + Sequence Table
- **SPL Queries:**
 - *Total Volume:* index=depi host=PCAD "wevtutil.exe" | stats count
 - *Execution Stream:*

```
index=depi host=PCAD "wevtutil.exe"
| eval Account_Name=coalesce(Account_Name, User, TargetUserName,
"Unknown")
| eval Activity=case(EventCode=4688 OR EventCode=1, "Process
Started", EventCode=5, "Process Terminated", 1=1, "Log Clearing
Activity")
| table _time, Account_Name, Activity, CommandLine, EventCode
| sort _time
```

Defense Evasion: Log Clearing - Defense Evasion: Log Clearing					Total Log Clearing Events - Total Log Clearing Events	
_time ↕	Account_Name ↕	Activity ↕	CommandLine ↕	EventCode ↕	124	
2026-04-25T18:06:57.97+03:00	NOT_TRANSLATED NT AUTHORITY\SYSTEM	Process Started	1?? IC:\Windows\system32\cmd host.exe /Q /I /C:ForceV1	1		
2026-04-25T18:06:57.98+03:00	NOT_TRANSLATED NT AUTHORITY\SYSTEM	Process Terminated		5		
2026-04-25T18:06:57.99+03:00	Administrator	Process Started		4688		

- **Technical Analysis:** Detects host-level defense evasion by tracking invocations of the Windows event log clearing utility. The standalone counter updates dynamically to highlight log-wiping loops, providing immediate oversight of the attacker's footprint suppression attempts.

6.3.7 Panel 7: C2 / Graphical Session Validation

- **Visualization Type:** High-Alert Table
- **SPL Query:**

```
index=depi host=PCAD Image="*\\rdpclip.exe"
| eval User=coalesce(User, user, Account_Name, "Unknown")
| table _time, User, Image, CommandLine
| sort _time
```

C2/RDP Session Confirmed - C2/RDP Session Confirmed

_time ↕	User ↕	Image ↕	CommandLI... ↕
2026-04-25T21:04:28.559+03:00	NOT_TRANSLATED PCAD/Administrator	C:\Windows\System32\rdpclip.exe	rdpclip
2026-04-27T14:17:15.663+03:00	NOT_TRANSLATED PCAD/Administrator	C:\Windows\System32\rdpclip.exe	
2026-04-27T14:26:38.976+03:00	NOT_TRANSLATED PCAD/Administrator	C:\Windows\System32\rdpclip.exe	rdpclip

- **Technical Analysis:** Serves as the high-fidelity confirmation panel for full interactive Command & Control (C2). By monitoring the execution of `rdpclip.exe` (which only initializes inside an active RDP environment), this panel supplies immediate validation that the adversary has achieved total graphical interface control over the asset.

6-Indicators of Compromise (IOCs)

⚠ INDICATORS OF COMPROMISE (IOCs)				Security Incident Report
Indicator Value	Type	Attack Phase	Description	
192.168.1.25	IP Address	Recon / Exploit	Attacker source IP (Kali Linux)	
hacker11 / hacker2	User Account	Persistence	Backdoor accounts with Admin privileges	
rdpclip.exe	Process	GUI Access	Artifact confirming active RDP session	
wevtutil.exe	Process	Defense Evasion	Used to systematically clear audit logs	
net.exe / reg.exe	Process	Persistence	Account management and registry modification	
Port 5985	Network Port	Initial Access	Exploited WinRM service for initial remote shell	
Port 3389	Network Port	GUI Access	Exploited RDP service for graphical control	
Event ID 4732	Event Code	PrivEsc	Member added to Administrators group	
Event ID 4625	Event Code	Delivery	Documented failed brute force attempts	
fDenyTSConnections=0	Registry Value	Defense Evasion	Key modified to bypass RDP access restrictions	

Attack Phase Legend

Initial Access Recon / Exploit Persistence Defense Evasion GUI Access

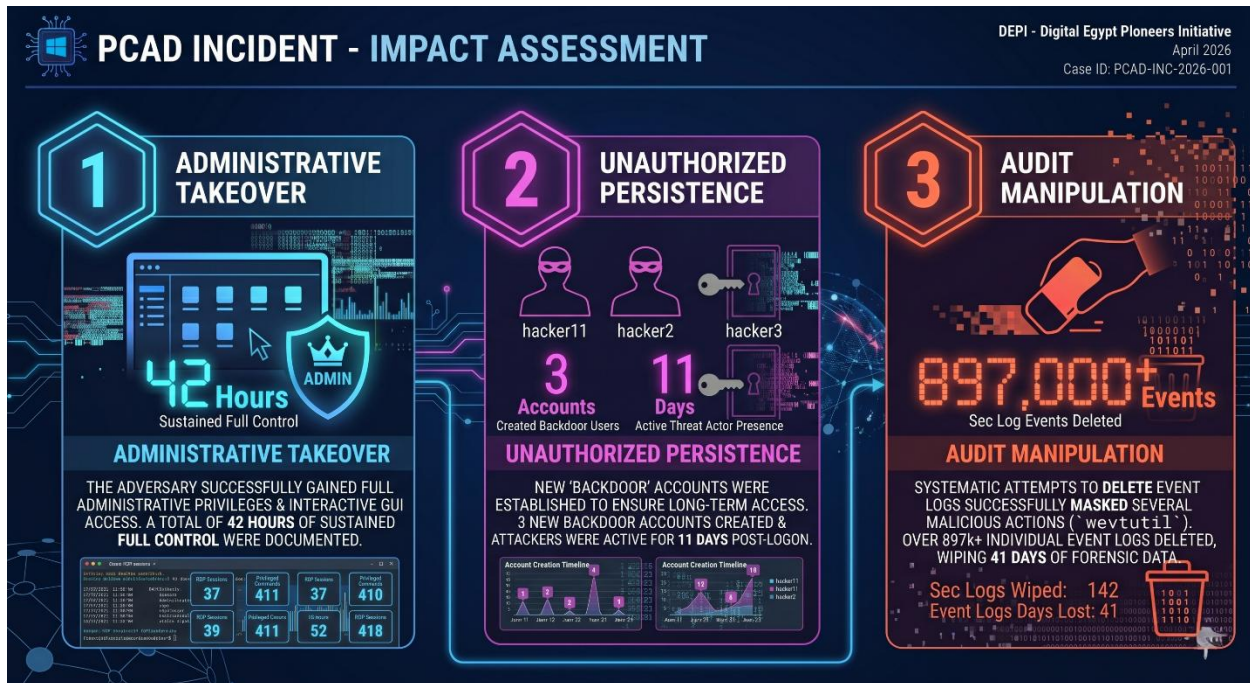
PrivEsc Delivery

Source IP: 192.168.1.25 (Kali Linux) — All indicators relate to a single coordinated attack chain

7. Impact Assessment

1. **Administrative Takeover:** The adversary successfully gained full administrative privileges and interactive GUI access.
2. **Unauthorized Persistence:** New "backdoor" accounts were established to ensure long-term access.

3. **Audit Manipulation:** Systematic attempts to delete event logs successfully masked several malicious actions.



8. Containment & Remediation

 **Active incident detected — immediate action required on host 192.168.1.12**



Step 1 — Isolation

Terminate the adversary's active connection immediately

Critical · Do now

● Do this

- ✓ Immediately disconnect 192.168.1.12 from the network
- ✓ Block the attacker IP 192.168.1.25 at the firewall level
- ✓ Preserve memory and disk image before shutdown for forensics
- ✓ Notify the incident response team right away

● Don't do this

- ✗ Don't shut down the machine first — you'll lose volatile memory evidence
- ✗ Don't keep the host online while investigating — attacker may be watching
- ✗ Don't delete logs before capturing a full copy

 Port 5985 (WinRM) and 3389 (RDP) must be blocked at the perimeter firewall — not just on the host.



Step 2 — Eradication

Remove all attacker footholds from the system

High priority

● Do this

- ✓ Delete backdoor accounts: hacker11 and hacker2
- ✓ Force an immediate password reset for the Administrator account
- ✓ Audit all accounts with Admin privileges — remove any that are unauthorized
- ✓ Revert registry key fDenyTSConnections back to 1

● Don't do this

- ✗ Don't just disable the accounts — delete them and verify they're gone
- ✗ Don't reuse old passwords — use a strong unique credential
- ✗ Don't assume one host is the only affected machine — check laterally

 Check Event ID 4732 logs to find every account that was added to Administrators — there may be more than two backdoors.



Step 3 — Hardening

Close the attack surface so it can't happen again

Long-term fix

● Do this

- ✓ Disable WinRM (port 5985) unless strictly needed for management
- ✓ Disable RDP (port 3389) or restrict it to VPN-only access
- ✓ Enforce MFA for all remote access — no exceptions
- ✓ Enable account lockout policy after failed login attempts

● Don't do this

- ✗ Don't leave RDP or WinRM open to the internet without authentication controls
- ✗ Don't rely on passwords alone — brute force (Event ID 4625) will happen again
- ✗ Don't skip log monitoring — wevtutil was used to erase tracks; set up alerts

 If RDP must stay enabled, restrict access by IP whitelist and move it off the default port 3389.